

Matriz de Evaluación PRAGMATIC Completa – Indicadores OWASP 2025 (M1-M15)

Versión 1.0 – Borrador. Escala de puntuación por criterio: 0 (muy pobre) a 5 (excelente).

Esta matriz resume, para cada indicador M1-M15, su objetivo GQM sintetizado y la valoración cualitativa según los nueve criterios PRAGMATIC.

1. Leyenda de puntuaciones

- 5 – Excelente: Cumple de forma sobresaliente el criterio, con pocas reservas prácticas.
- 4 – Buena: Cumple bien el criterio; las limitaciones son asumibles.
- 3 – Aceptable: Cumple lo mínimo razonable; requiere contexto y prudencia.
- 2 – Débil: Cumple parcialmente; solo útil en combinación con otros indicadores.
- 1 – Muy débil: Utilidad limitada; generalmente desaconsejado como métrica principal.
- 0 – Nulo: No cumple o induce a conclusiones engañosas.

2. Matriz PRAGMATIC para M1-M15

ID	Objetivo GQM (resumen)	P (Predictivo)	R (Relevante)	A (Accionable)	G (Genuino)	M (Significativo)	A (Preciso)	T (Oportuno)	I (Independiente)	C (Rentable)	Comentario sintético
M1	Cuantificar la exposición estructural a vulnerabilidades OWASP Top 10:2025 en sistemas españoles.	4	5	4	4	5	3	3	3	3	Muy útil para anticipar tendencias de riesgo técnico por categoría; depende de la calidad del inventario y reporting de CVEs, con coste de consolidación moderado.

M2	Evaluar robustez de activos críticos frente a A01–A03 (acceso, configuración, cadena de suministro).	5	5	5	4	5	3	3	3	3	Altamente alineado con NIS2/ENS; directamente accionable (priorizar remediación en activos “no limpios”); precisión sujeta a calidad de escaneos y definición de criticidad.
----	--	---	---	---	---	---	---	---	---	---	--

M3	Medir cober tura de prueb as de seguri dad explic itame nte mape adas a Top 10:20 25.	3	4	4	4	4	3	4	3	4	Buen a aprox imaci ón a capac idad de detec ción; predi ctivo a medio plazo sobre hallaz gos; relati vame nte barat a si se apoya en herra mient as CI/CD y ASPM .
----	--	---	---	---	---	---	---	---	---	---	---

M4	Medir el tiempo medio de remediación de vulnerabilidades Top 10 en activos críticos.	4	5	5	4	5	4	3	4	4	Indicador clásico de eficiencia operacional, muy accionable (ajuste de SLAs, recursos); precisión razonable si se usa ticketing centralizado; recogida de datos de bajo coste incremental.
----	--	---	---	---	---	---	---	---	---	---	--

M5	Evaluar madurez media SAM M por función (Gobernanza, Diseño, Implementación, Verificación, Operaciones).	3	5	4	4	4	3	3	3	3	Buen término de capacidad; predictivo pero a medio-largo plazo; requiere autoevaluaciones y cierto esfuerzo de facilitación, pero costes controlables con plantillas SAM M.
----	--	---	---	---	---	---	---	---	---	---	---

M6	Estimar % de entidades con nivel ≥ 2 en “Strategy and Metrics” (SAMM).	3	5	4	4	4	3	3	3	3	Refuerza la visión de gobernanza basada en métricas; útil para políticas nacionales; depende de honestidad y consistencia en autoevaluaciones.
-----------	---	---	---	---	---	---	---	---	---	---	--

M7	Medir la pendiente de mejora SAM M (Δ SA MM) anual por práctica.	4	4	4	4	4	3	3	3	3	Buen indicador de dinámica de cambio (no solo foto fija); predictivo sobre evolución futura; barato o una vez implantado M5/M6.
----	--	---	---	---	---	---	---	---	---	---	---

M8	Medir la cobertura de autoevaluaciones SAM M en sectores regulados.	2	4	3	4	3	4	4	4	4	Mide más la disciplina de medición que la seguridad en sí; muy barato y fácil de verificar; útil como indicador de “higienemétricas”.
----	---	---	---	---	---	---	---	---	---	---	---

M9	Evaluar la adecuación de niveles ASVS a la criticidad ENS/NIS2 de las aplicaciones.	4	5	5	4	5	3	3	3	3	Muy relevante y accionable (subir niveles ASVS para apps críticas); predictivo de probabilidad de fallos técnicos serios ; exige clasificaciones y evaluaciones ASVS sistémicas.
----	---	---	---	---	---	---	---	---	---	---	--

M10	Medir % de requisitos ASVS cumplidos por capítulo técnico.	3	5	4	4	4	3	3	3	3	Excelente para identificar áreas técnicas débiles (autenticación, criptografía, etc.); requiere mapeo o disciplina de controles y puede ser costoso si se hace manualmente.
-----	--	---	---	---	---	---	---	---	---	---	---

M11	Medir cobertura de pruebas frente a requisitos ASVS (automatizadas y manuales).	3	4	4	4	4	3	3	3	3	Completa a M10: habla de “muscultura de verificación”; predictivo en la medida en que mayor cobertura tiende a correlacionar con menos defectos en producción.
-----	---	---	---	---	---	---	---	---	---	---	--

M12	Medir ratio de requisitos ASVS no cumplidos detectados en producción por volumen de uso.	4	5	5	4	5	3	3	3	3	Métrica muy significativa (mide deuda de seguridad que escapa al SDLC); ; accionable (refuerzo de fases débiles); dependiente de la calidad de incidentes/auditorías, recopilación algo más costosa.
-----	--	---	---	---	---	---	---	---	---	---	--

M13	Medir distribución de severidad OWASP (baja/mediana/alta) en infraestructuras críticas.	4	5	4	4	4	3	3	3	3	Complementa a CVSS con enfoque OWASP; útil para priorizar sectores y sistemas; predictivo de probabilidad de incidentes, aunque dependiente de metodologías de scoring coherentes.
-----	---	---	---	---	---	---	---	---	---	---	--

M14	Medir riesgo medio OWASP normalizado por sector (score 1-10).	5	5	4	4	4	3	3	3	3	Muy potente para comparativas intersectoriales y priorización de políticas; altamente predictivo a nivel macro; exige modelo de cálculo transparente y datos fiables.
-----	---	---	---	---	---	---	---	---	---	---	---

M15	Medir tiempo medio desde detección técnica hasta decisión ejecutiva de riesgo.	4	5	5	4	5	3	3	4	4	Excelente indicador de gobernanza y alineamiento técnico-negocio; muy accionable (reforma de flujos de decisión); coste de medición moderado si se integran flujos de reporte.
-----	--	---	---	---	---	---	---	---	---	---	--

3. Lectura transversal de la matriz

- La mayoría de métricas M1–M15 puntúan alto en Relevancia (R), al estar alineadas con riesgos y obligaciones de NIS2/ENS y con prácticas OWASP ampliamente reconocidas.[web:2][web:21][web:24][web:68][web:97]
- Las métricas más operativas (M2, M4, M9, M12, M15) destacan en Accionabilidad, al vincularse claramente con decisiones concretas (remediación priorizada, elevación de niveles ASVS, cambios en flujos de decisión).
- Métricas como M5–M8 (SAMM) son especialmente útiles para políticas de madurez de programa, con alta relevancia estratégica pero menor inmediatez en predicción de incidentes.
- M1, M13 y M14 aportan mayor peso predictivo a escala macro, siempre que se disponga de una base de datos de vulnerabilidades y riesgos suficientemente amplia y de calidad.[web:87][web:95][web:98][web:99]

En el uso práctico, se recomienda:

- Seleccionar un subconjunto de métricas con puntuaciones globales altas (por ejemplo, M2, M4, M9, M12, M14, M15) para cuadros de mando de alto nivel.
- Mantener el resto como indicadores de segundo nivel o de diagnóstico detallado.
- Revisar periódicamente las puntuaciones PRAGMATIC a la luz de la experiencia real.